

Change Handout

Tenant Licensing & Onboarding Overhaul

Engineering reference · 20–22 Jun 2026 · CRM Platform

1. Overview

What changed: we introduced a Salesforce-style two-layer access model. The super admin licenses **modules + feature-areas** to a workspace; the tenant admin then decides **who can view / create / edit / delete** within those licensed features. Both are now enforced end-to-end.

Layer	Owner	Question it answers	Stored in
Entitlement	Super admin	What did the customer buy?	tenants.entitled_features / active_modules
Permissions	Tenant admin	Who may act within what was bought?	roles.permissions (granular booleans)

Enforcement is now three layers deep on protected routes:

- `requireEntitlement(...features)` — is the workspace licensed for the feature?
- `requireScope(...)` — does the user's role tier allow it? (pre-existing)
- `requirePermission(key)` — does the user's role grant this exact action?

2. Database

Migration 023_tenant_entitlements.sql

```
ALTER TABLE tenants
  ADD COLUMN IF NOT EXISTS active_modules TEXT[] NOT NULL DEFAULT ARRAY['crm'],
  ADD COLUMN IF NOT EXISTS entitled_features JSONB NOT NULL DEFAULT '[]'::jsonb;
```

- `active_modules` — top-level licensed modules, e.g. `['crm', 'sales']`.
- `entitled_features` — the agreed feature allow-list, e.g. `["crm.contacts", "sales.invoices"]` — the entitlement source of truth.

Migration drift: the ordered runner is blocked on 008_sales_invoicing.sql in the dev DB (objects exist, row missing in `_migrations`). 023 was applied directly and recorded; reconcile before relying on the ordered runner.

3. Backend changes

File	What changed
routes/super-admin.ts	MODULE_CATALOG is the single source of truth with a <code>features[]</code> list per module. Removed ticketing/voice/voicebot, added sales. <code>POST /tenants</code> now derives <code>active_modules</code> from selected features, stores entitlements,

File	What changed
	provisions the tenant_admin login (+ one-time temp password), and auto-seeds the 4 system roles.
routes/roles.ts	Added Sales permission modules (invoices, billing_contacts, payments, sales_reports, invoice_templates, sales_settings). New MODULE_LICENSE_REQUIREMENT map + entitledModuleDefs(); GET /roles/modules now returns only licensed modules (legacy/empty = all).
middlewares/auth.middleware.ts	New requireEntitlement(...features) (403 NOT_LICENSED) and requirePermission(key) (403 FORBIDDEN; admin bypass; absent key = allow for backward-compat).
routes/modules.ts	NAV_FEATURE_MAP + filterByEntitlement() hide unlicensed nav items from the sidebar.
routes/sales/*.ts	Module-level requireEntitlement hook + per-route requirePermission keys on invoices, billing-contacts, sales-settings, invoice-templates.

3.6 Bug fixes found along the way

- `await import('bcrypt') → (await import('bcryptjs')).default` (3 sites) — bcrypt was never a dependency; this also repaired the existing Add-User / Edit-User handlers.
- users INSERT used a non-existent `status` column → changed to `is_active = true`.
- **Sales dashboard:** added missing `.then(r => r.rows)` on 5 queries; replaced non-existent `amount_due/amount_paid` columns with a payments LEFT JOIN; fixed alias-less FILTER clauses.
- **Invoice partial payments:** status now derives — partially paid when $0 < \text{paid} < \text{total}$, paid when $\text{paid} \geq \text{total}$ — and the list view matches the detail view via a payments JOIN.

4. Frontend changes

File	What changed
pages/SuperAdmin.tsx	Create Workspace modal reduced from 3 steps to 2 (details+admin, then a module→feature selection tree). Added admin password block (auto-generate toggle). Removed the role-permissions step (auto-seeded server-side). One-time credentials success screen. Agreed Features chips on the workspace profile.
App.tsx	Super admin landing fix: super admins land on /super-admin; /dashboard redirects them there; they no longer see the operational ticket/voice dashboard.

5. How to test

- Create a workspace via Super Admin → Tenants → New Workspace; license e.g. CRM + Sales Invoices only; capture the temp password.
- Log in as the new tenant admin and confirm: sidebar SALES shows only Dashboard + Invoices; Roles screen shows only licensed modules incl. Invoices CRUD.

- API: GET /api/v1/sales/invoices → 200; GET /api/v1/sales/settings → 403 NOT_LICENSED.

Dev super-admin login: workspace demo, admin@demo.com / Demo1234!. Note: /super-admin is API-proxied on full-page loads — navigate client-side in the SPA.

6. Known gaps / follow-ups

- Email + password lifecycle: temp password is shown once on screen only — to do: email it on creation, and add a regenerate/reset flow.
- NAV_FEATURE_MAP covers CRM + Sales paths; extend as more modules gain feature-level licensing.
- Super-admin "Manage Roles" modal filters by the super admin's own tenant entitlement; pass the target tenant id to reflect that tenant.
- CRM routes still enforce at role-tier; only Sales was tightened to granular keys. Align for symmetry if desired.